



Google.org
**CYBERSECURITY
SEMINARS**
ARISTOTLE UNIVERSITY OF THESSALONIKI



Security Information and Event Management

Part I

Prof. Andreas L. Symeonidis, PhdC George Siachamis, PhdC Dimosthenis Natsos

{symeonid, gsiacha, cdnatsos}@ece.auth.gr

*Electrical & Computer Engineering Dept
Aristotle University of Thessaloniki
<https://issel.ee.auth.gr>*

*Cyclopt
Software Quality Assessment
<https://www.cyclopt.com>*



What you have learned so far

- Cybersecurity basics
- Introduction to Cryptography
- Cryptographic Engineering
- Network Security
- General Data Protection Regulation (GDPR)
- Network and Information Security Directive (NIS 2)

Next: Security Information and Event Management (SIEM)

Lecture Outline

- Infrastructure security
- The Cyber Security Teams
- Levels of Infrastructure Security
- State of Practice
- Security Operation Centre (SOC) Basics
- Tools in SOC
- Security Information and Event Management (SIEM)
- SIEM toolchain demo

Infrastructure Security

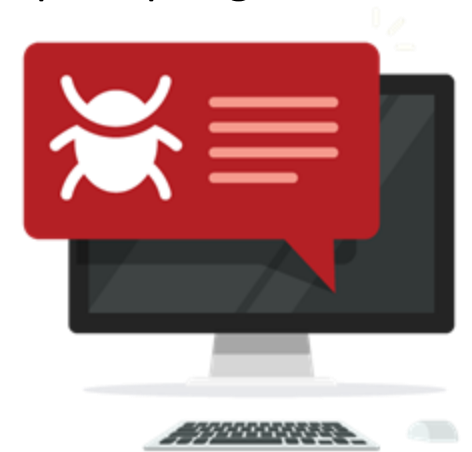
What is Infrastructure Security

- Overall goal: keeps businesses running smoothly by protecting both physical and digital assets (for IT systems)
- Refers to: the measures and strategies employed to protect an organization's digital and physical infrastructure assets from a variety of threats. Those ensure:
 - Confidentiality
 - Integrity
 - Availability
- Regardless of how it is done, infrastructure monitoring is needed!
- Monitoring involves continuous observation of assets for threats, anomalies and compliance violations



IT Infrastructure Threats

- **Ransomware:** A kind of malware that encrypts data and asks for monetary incentives to decrypt
- **Malware:** Any kind of malicious software that can harm the infrastructure in any way
- **Phishing Attempts:** Content (forged emails, suspicious links, etc) that seems realistic, prompting humans to share sensitive information (passwords, user credentials, etc)
- **Data Breaches:** Unauthorized exposure, exfiltration and loss of sensitive information
- **DoS/DDoS:** Attacks that aim towards making a service misbehave or be completely unavailable
- **Identity Theft:** Malicious actors steal user tokens or impersonate users with elevated rights to gain unauthorized access
- **Cloud Misconfigurations:** Misconfigurations, insecure APIs, and poor access management that leads to vulnerable points within the infrastructure



Server-side, Client-side, Virtualized Security

- **Server-side Security:** Refers to the protective measures implemented on the back-end of a web application, where critical processes, data storage, and user authentication occur.
 - Common Threats: SQL Injection, Distributed Denial of Service, Server Misconfiguration
- **Client-side Security:** Protects the user-facing components of a web application—primarily what runs in the browser—from malicious code injections, third-party script abuse, and data exfiltration.
 - Common Threats: Reverse Engineering, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF)
- **Virtualized Security:** Refers to security solutions that are software-based and designed to work within a virtualized IT environment.
 - Common Threats: Insecure API, Poor Network Configuration, Hypervisor Security Controls

Continuous monitoring is imperative for effective security in all of the aforementioned categories!!!

Logging: persistence in a digital world

- **What Are Logs (in a cyber security context)**
 - Time-stamped records of system, application, and security events automatically generated by IT infrastructure.
 - Capture "who did what, when, where, how, and the result" for every significant activity .
- **Why Logs Matter for Security**
 - Primary source of forensic evidence for incident investigation and attacker reconstruction.
 - Enable real-time threat detection through pattern analysis and correlation.
 - Required for compliance (NIS2, GDPR) with mandatory audit trails and retention.
- **Two Fundamental Types**
 - **Operational Logs:** System health, performance, troubleshooting (e.g. CPU, memory, errors).
 - **Security Logs:** Authentication, access control, policy violations, suspicious activity.



Common Log Types (1)

- **Operating System (OS) & Endpoint Logs:** Detect lateral movement, privilege escalation, malware execution, unauthorized access
- **Application Logs:** Identify compromised accounts, data exfiltration, application-level attacks, misuse
- **Firewall & Network Security Device Logs:** Detect command-and-control (C2) communications, external reconnaissance, data exfiltration attempts
- **Intrusion Detection/Prevention (IDS/IPS) & Network Monitoring Logs:** Capture known attack signatures and unusual network behavior in real time



Common Log Types (2)

- **Web Application Firewall (WAF) Logs:** Detect and block web-based attacks, identify vulnerable or misconfigured applications
- **Cloud Platform Logs (AWS CloudTrail, Azure Activity Log, GCP Cloud Audit Logs):** Detect unauthorized cloud activity, misconfigurations, privilege escalation, data leakage
- **Identity Provider (IdP) & SSO Logs:** Spot account takeovers, brute-force attacks, privilege misuse, suspicious
- **VPN & Remote Access Logs:** Detect unauthorized remote access, abnormal connection patterns, compromised credentials



Log Elements

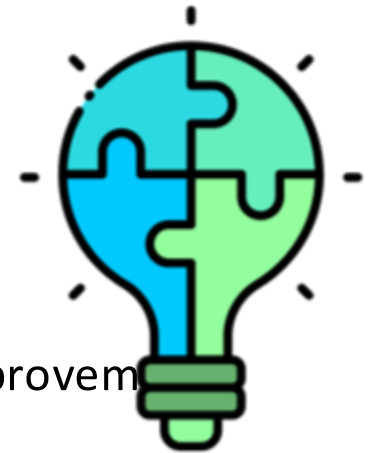
- **Timestamp:** precise time (ideally with timezone and millisecond precision) to correlate events across systems
- **Source/System:** which device, server, application, or service generated the event; critical for asset mapping
- **Identity:** who performed the action (user account, service account, IP address); links events to actors
- **Action:** what was attempted or performed (login, file read, privilege grant, network connection)
- **Result:** success or failure outcome; helps distinguish normal behavior from suspicious attempts
- **Context:** additional details (resource accessed, target system, method used, risk indicators) that clarify the event's significance

When are logs useful...

- **A single log entry should tell a story:** who did what on which system at what time, and whether it succeeded.
- Incomplete or vague logs (missing timestamps, no identity information, unclear results) waste analyst time and reduce detection quality.
- Rich context reduces false positives and speeds up triage decisions.



- Actionable insights from logs enable faster incident response and continuous security improvement
- Log data and events should map to some sort of use case



Security Operations Center (SOC)

Cyber Security Teams

- **Red Team (Offensive Security)**

- Simulate cyberattacks to test organizational defenses and identify vulnerabilities
- Perform penetration testing, exploit development, social engineering assessments
- Help improve security posture by revealing gaps before real attackers do



- **Blue Team (Defensive Security) ← Our focus**

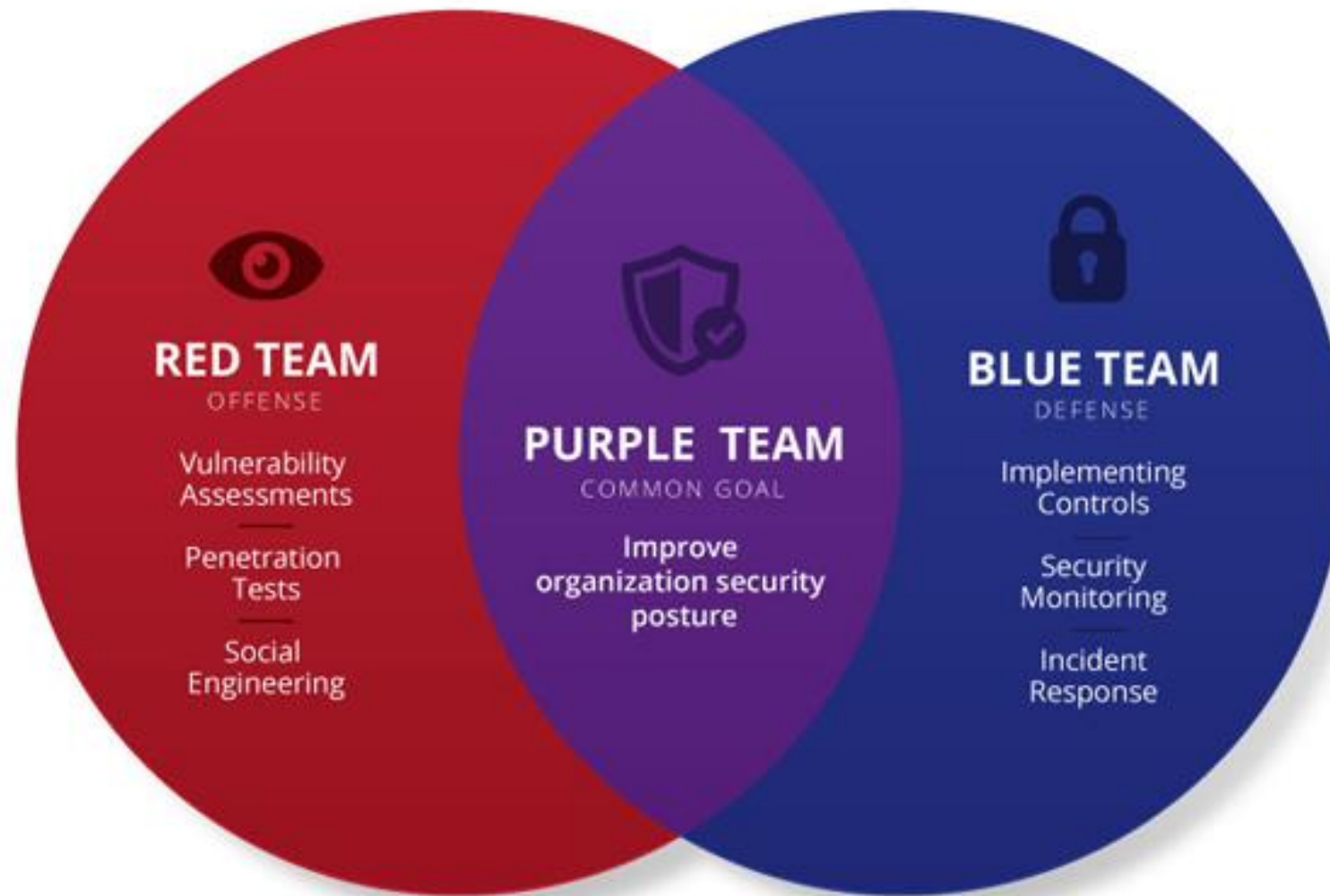
- Responsible for monitoring, detecting, and responding to security incidents
- Maintain and tune security tools (SIEM, EDR), analyze alerts, conduct threat hunting



- **Purple Team (Collaborative Security)**

- Bridge between Red and Blue teams to enhance communication and effectiveness
- Facilitate knowledge sharing, validate defenses through joint exercises
- Blend offensive tactics with defensive strategies to continuously improve security





Security Operations Center (SOC)

- Centralized team dedicated to **monitoring, detecting, analyzing, and responding** to cybersecurity incidents 24/7.
- Ensures the **confidentiality, integrity, and availability** (CIA triad) of organizational information assets.
- Acts as the **nerve center** integrating people, processes, and technology to manage cyber risk.
- Supports business objectives by **reducing downtime, data breaches, and operational losses**
- Facilitates **compliance with regulations** such as NIS2, GDPR, HIPAA by implementing continuous monitoring, logging, and reporting.
- Helps enforce **governance, risk management, and compliance (GRC) policies** through real-time telemetry analysis and documented procedures.



SOC Tiers and Responsibilities

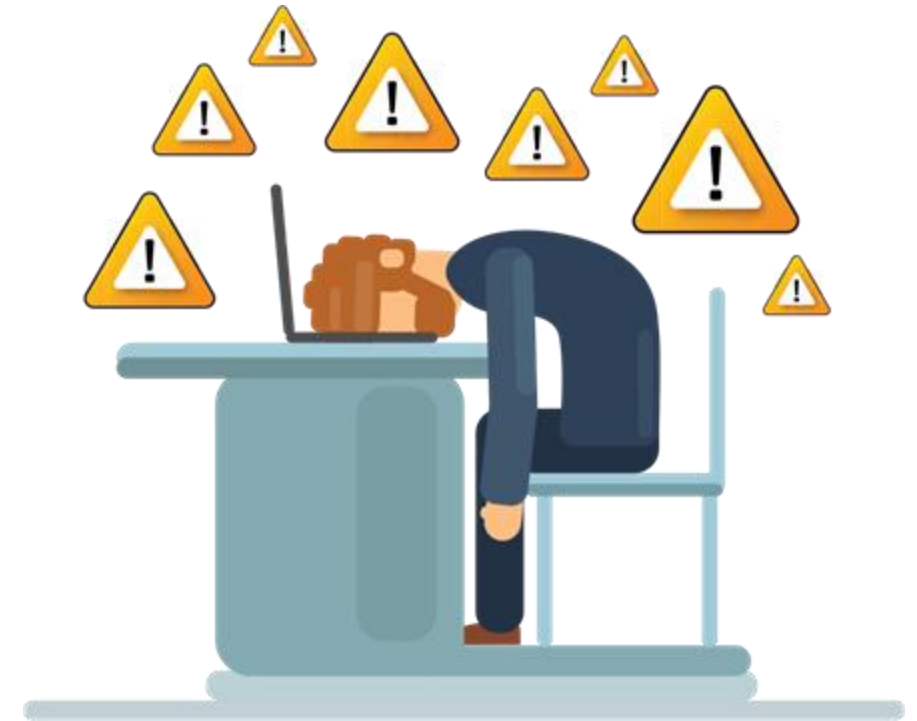
- **Tier 1 (Junior Analysts - SOC L1 Analysts Entry Level)**
 - Continuous monitoring of security tools (SIEM, EDR) and alert dashboards
 - Initial alert triage: categorize, prioritize, and dismiss false positives
 - Basic documentation and escalation of suspicious alerts to Tier 2
 - Builds foundational skills in real time threat detection
- **Tier 2 (Incident Responders - SOC L2 Analysts)**
 - Deep investigation of escalated alerts using log analysis and threat intelligence
 - Incident response: scope determination, evidence collection, root cause analysis
 - Containment actions for confirmed incidents and playbook execution
 - Requires 1–2 years experience; focuses on technical investigation skills
- **Tier 3 (Senior Analysts - Threat Hunters)**
 - Advanced threat hunting, malware reverse engineering, custom detection rules
 - Strategic improvements: tool tuning, process refinement, adversary emulation
 - Leads major incident response and mentors lower tiers
 - Expert level; often involves research and long term security architecture

SOC Pyramid



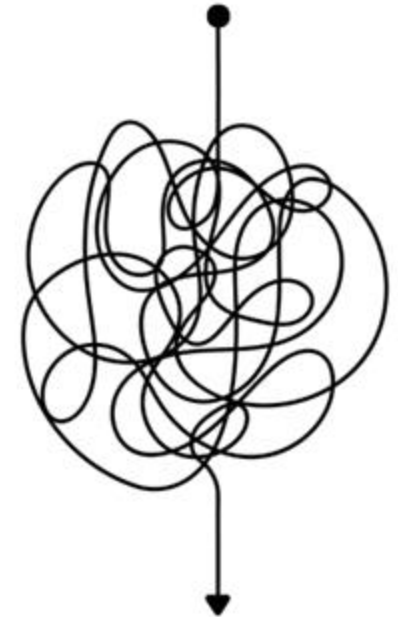
SOC Challenges (1)

- **Alert Fatigue & Overwhelming Alert Volume**
 - Average SOCs receive 10,000+ alerts per day; most are false positives or low priority noise
 - Constant alert streams lead analysts to miss critical incidents buried in the noise
 - Cognitive overload reduces effectiveness and increases decision errors
- **Manual & Time Intensive Processes**
 - Alert triage, escalation, documentation, and reporting consume disproportionate analyst time
 - Repetitive low value work diverts attention from proactive threat hunting and improvement
 - Manual workflows slow incident response times (average MTTR: 2.3 days)



SOC Challenges (2)

- **Lack of Unified Visibility**
 - Fragmented tools, siloed data sources, and blind spots in cloud/remote environments
 - Analysts piece together data from disparate systems instead of having a single unified view
 - Missing visibility leads to undetected threats and slower incident investigations
- **Integration & Tool Complexity**
 - SOC's often operate with poorly integrated disparate tools (SIEM, EDR, firewalls, ticketing)
 - Setup, maintenance, and troubleshooting become resource heavy with minimal security gain
 - Inconsistent context across tools increases investigation friction
- **Talent Shortage & Skill Gap**
 - Insufficient pool of experienced SOC analysts to fill open positions
 - New graduates lack hands-on experience; training is expensive and time consuming
 - Staffing levels often insufficient for 24/7 operations and proactive defense



SOC Challenges (3)

- **Compliance & Reporting Pressure**
 - Multiple regulatory frameworks (NIS2, GDPR, HIPAA, etc) demand comprehensive documentation.
 - Compliance work diverts resources from core incident response and threat detection.
 - Risk of audit failures and organizational penalties for noncompliance.
- **Limited Threat Detection Capabilities**
 - Rules and detection methods often catch only obvious threats; miss sophisticated attacks.
 - Poor threat intelligence integration limits context during investigations.
 - Reactive posture rather than proactive threat hunting.



SOC Workflows - Incident Response (1)

- **Intake (Alerts & Tickets)**

- Alerts from SIEM correlation rules, EDR, firewalls flood Tier 1 queues.
- Tickets from users or automated systems reporting suspicious activity.
- Initial filtering to manage volume and focus on high priority signals.

- **Triage**

- Tier 1 assesses alert validity, severity, and context (who/what/when).
- False positive dismissal vs. escalation with initial findings documented.
- Prioritization based on impact, confidence, and business criticality.

- **Escalation**

- Tier 2 takes over for deeper analysis if Tier 1 cannot resolve.
- Clear handoff with summary, evidence, and recommended next steps.
- Ensures continuity while respecting tier expertise boundaries.



SOC Workflows - Incident Response (2)

- **Containment**

- Isolate affected systems (network segmentation, account disablement).
- Prevent spread while preserving evidence for investigation.
- Balance speed with forensic integrity.

- **Eradication**

- Remove malware, reset credentials, patch exploited vulnerabilities.
- Full cleanup to eliminate attacker persistence mechanisms.
- Verify no remnants before recovery.

- **Recovery**

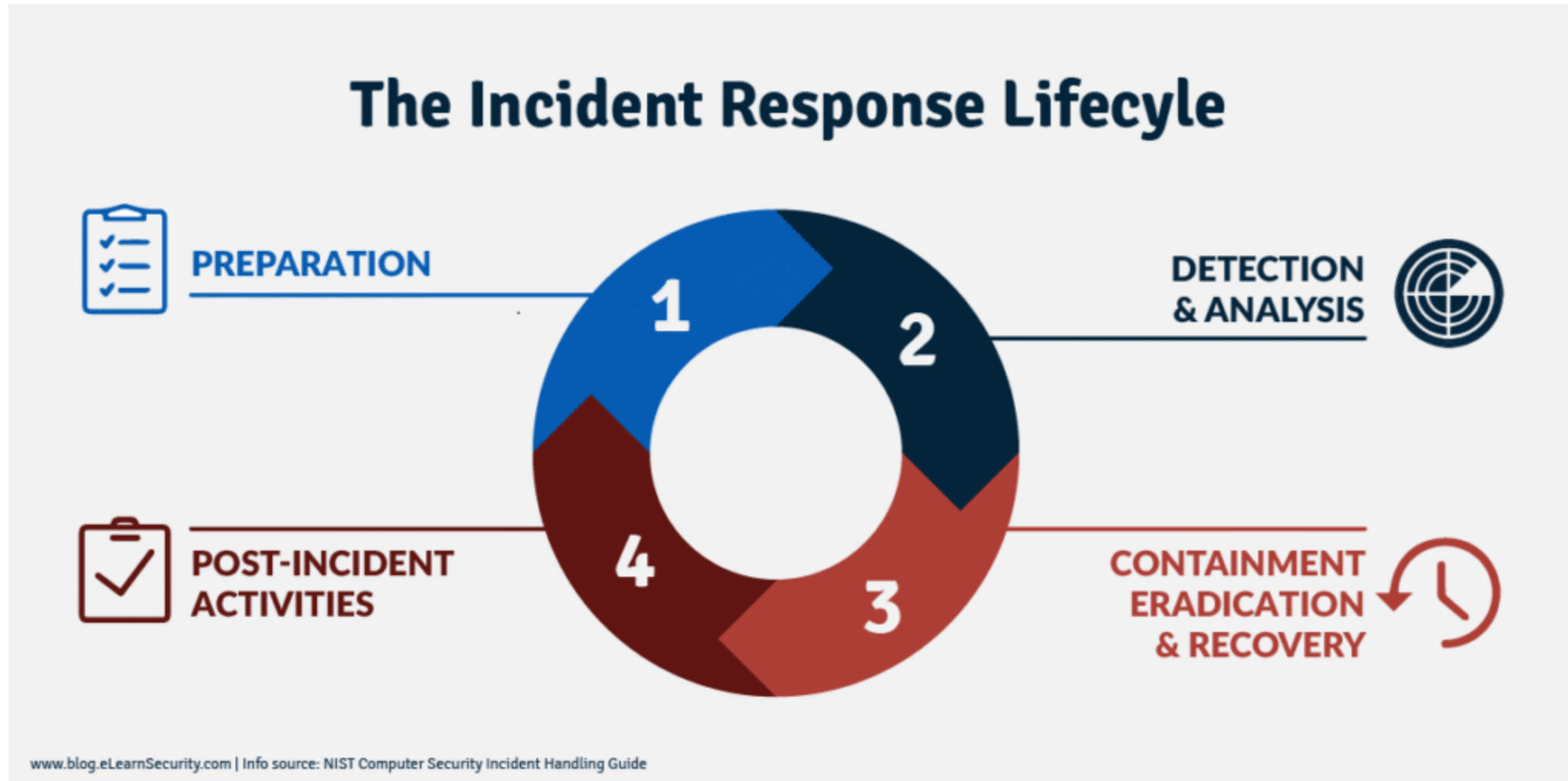
- Restore systems from clean backups with enhanced monitoring.
- Gradual return to operations while validating security posture.
- Communicate status to stakeholders.

- **Lessons Learned**

- Post Incident review: timeline, gaps, improvements identified.
- Update playbooks, rules, training based on findings.
- Metrics capture for continuous SOC maturity.



SOC Workflows - Incident Response



SecOps Tools Overview (1)

- **Monitoring & Alerting Tools**
 - SIEM (Security Information and Event Management): Collects and analyzes logs and events from across the infrastructure to detect and alert on security incidents.
 - EDR (Endpoint Detection and Response): Provides deep visibility into endpoint activity, enabling detection, investigation, and response to advanced threats.
 - Network monitoring tools: firewalls, IDS/IPS, NetFlow analyzers for traffic visibility.
- **Investigation & Analysis Tools**
 - Log analysis platforms: search and filter logs across all sources for forensic investigation.
 - Threat intelligence platforms: correlate findings against known indicators of compromise (IOCs).
 - Threat hunting tools: behavioral analytics, anomaly detection for proactive discovery.
- **Ticketing & Workflow Management**
 - Incident management systems: track alerts through triage, investigation, containment, and recovery.
 - Playbook automation engines: standardize response workflows and reduce manual effort.
 - Communication platforms: Slack, Teams for cross team collaboration and escalation.

SecOps Tools Overview (2)

- **Containment & Response Tools**

- EDR remote execution: isolate systems, disable accounts, kill malicious processes.
- Orchestration platforms (SOAR): Aggregates data from SIEM, EDR, and other tools to automate workflows, and accelerate incident response.
- Access management systems: credential reset, privilege revocation, MFA enforcement.

- **Forensics & Evidence Collection**

- Memory acquisition tools: capture volatile data before system restart.
- Disk imaging tools: preserve full system state for offline analysis.
- Chain Of Custody documentation systems: ensure evidence integrity for legal proceedings.

- **Reporting & Metrics Tools**

- Dashboard and visualization platforms: executive summaries, KPIs, trend analysis.
- Case management systems: centralized documentation of incidents and resolutions.
- Compliance reporting tools: automate regulatory audit trails and evidence gathering.

SecOps Proprietary Tools



SecOps Open-Source Tools



Security Information & Event Management (SIEM)

What is SIEM

Security Information and Event Management (SIEM) collects and aggregates log and event data from multiple sources (servers, endpoints, network devices, applications). Such a system offers:

- **Log Aggregation:** Centralizes raw logs to one platform for simplified access and analysis.
- **Normalization:** Transforms diverse log formats into a common schema to enable consistency.
- **Correlation:** Applies rules that link related events across systems into alerts on suspicious activities.
- **Alerting:** Generates prioritized security alerts based on correlated events for analyst investigation.
- **Dashboards & Reporting:** Real-time visualization of security posture, trends, and compliance status.
- **Basic Incident Workflow Support:** Tracks alert lifecycle from detection to resolution, integration with ticketing and response tools.

What SIEM is Not

- **A prevention tool:** SIEM detects and alerts but doesn't block threats on its own.
- **A replacement for endpoint or network security:** It aggregates data but does not provide endpoint protection or network traffic inspection directly.
- **A fully automated response system:** SIEM alerts analysts but requires human or SOARdriven action.

SIEM's Role in the Ecosystem

- Acts as the “**central nervous system**” aggregating and correlating security data across tools.
- Provides **contextual alerts** that feed into human decision-making or automated SOAR workflows.
- **Does not replace** endpoint/network/hardware security tools—works alongside them to unify and amplify detection and response.

Why SIEM

- Enormous **volume of logs** across diverse systems and security tools.
- **Disconnected tools** → fragmented visibility, manual correlation.
- Enables **unified, comprehensive monitoring** and faster threat detection.
- Correlation links separate events into **meaningful security incidents** (e.g., multiple failed logins + unusual network activity).
- Compliance and regulatory demands **require** automated logging, reporting, and audit trails.
- **SIEM bridges gaps** between tools and scales security operations for complex, distributed environments.



Common SIEM Use Case Categories

- **Malware detection:** signatures and behavioral indicators of malicious files or processes.
- **Lateral movement:** unusual authentication patterns, privilege escalation, anomalous network access.
- **Data exfiltration:** large file transfers, unusual egress traffic to external IPs.
- **Insider threats:** privilege misuse, off hours access, mass data downloads.
- **Brute Force attacks:** repeated failed authentication attempts from same source.
- **Privilege escalation:** unauthorized admin activity, service account misuse.

Correlation and Detection Rules

- Correlation: Linking **related security events** occurring over time or across different systems.
- Detection of **complex attack patterns** missed by single event monitoring.
 - Example: Multiple failed logins **followed by** a successful login from an unusual location.
- Detection rules → Conditions and thresholds that **trigger alerts** based on correlated events.
- Rules **combine data** from various sources (endpoints, servers, network, identity systems).
- The goal is to produce **meaningful alerts** that accurately represent security incidents.



Use Cases

- **What is a "Use Case" (Business/Security Perspective)**
 - A specific security scenario or threat that an organization wants to detect and respond to.
 - Examples: "detect lateral movement across servers," "identify brute force login attempts," "spot data exfiltration."
 - Defines what you want to catch, why it matters, and what the business impact would be.
 - Driven by threat landscape, past incidents, compliance requirements, and risk assessments.
- **How Use Cases Become Detection Rules (Technical Translation)**
 - Business use case → Security analyst scopes the technical requirements.
 - Identify data sources: which logs contain signals for this threat (e.g., authentication logs for brute force)?
 - Define rule logic: what patterns or thresholds indicate the threat (e.g., >5 failed logins in 10 minutes)?
 - Build the rule: encode logic in SIEM query language (SQL, Splunk SPL, Sigma, etc.).
 - Test & tune: validate rule catches real threats with acceptable false positive rate.

Rule Lifecycle

- **Key Components of a Detection Rule**
 - Threshold: how many events or what volume triggers an alert (e.g., 3+ failed logins).
 - Time window: the span during which events are correlated (e.g., within 5 minutes).
 - Conditions: the specific fields and values to match (e.g., source IP, user account, result status).
 - Severity level: criticality assigned to the alert (Critical, High, Medium, Low).
 - Response action: what the SIEM or SOAR should do (e.g., escalate to Tier 2, block IP, disable account).

- **Rule Lifecycle & Continuous Improvement**
 - Rules are not "set and forget"—they require ongoing tuning and validation.
 - Monitor false positive rates and adjust thresholds as needed.
 - Update rules based on new threat intelligence, emerging attack techniques, and organizational changes.
 - Track detection metrics: Mean Time to Detect (MTTD), true positive rate, false negative rate.

Detection Coverage Tradeoffs

- **Detection Coverage:** How many real threats are caught by detection rules (true positives).
 - Increasing coverage often means more alerts, including many false positives (benign events flagged).
- **Alert Fatigue:** Analysts overwhelmed by excessive alerts tend to miss or ignore real threats.
- **False Positives:** Legitimate activities incorrectly flagged as suspicious, wasting analyst time.
- **False Negatives:** Actual security incidents missed by detection rules, leaving the organization exposed.
- **Tuning Detection Rules:** Balancing thresholds and conditions to maximize true positives and minimize false positives/negatives.
- Requires **continuous adjustment** based on environment changes and analyst feedback.
- Effective tuning improves **SOC efficiency** and threat detection **quality**.



Typical SIEM Usage Flow (1)

- **Data Collection:** The SIEM collects security-related data from diverse sources such as servers, network devices, firewalls, antivirus software, applications, and cloud platforms. This data usually includes logs, network traffic, and system events.
- **Event Correlation and Analysis:** The collected data is analyzed to identify patterns and correlations across different data sources. This helps to detect potential security incidents by identifying anomalies and suspicious activities.
- **Alert Generation:** When the SIEM detects a security threat, it generates alerts prioritized by severity. These alerts notify security teams promptly through various channels like email or dashboards.

Typical SIEM Usage Flow (2)

- **Incident Investigation:** Security analysts investigate the alerts by analyzing logs and additional contextual information to understand the nature and impact of the incident.
- **Incident Response and Management:** Based on the investigation, predefined or automated response actions are triggered to mitigate threats, such as isolating affected systems or blocking malicious IPs.
- **Reporting and Compliance:** SIEM tools provide reporting capabilities to support compliance requirements and give insights into security posture through dashboards and audit trails.
- **Continuous Monitoring and Improvement:** The SIEM process is iterative, with continuous tuning of detection rules, monitoring security events, and improving incident response capabilities based on lessons learned.

High-Level SIEM Rule Logic

Conditions (What to Look For)

- Specify event attributes or behaviors to match (e.g., failed login, source IP, user account).
- Focus on observable signs of suspicious activity or policy violations.

Thresholds (How Much or How Many)

- Define numeric limits that trigger alerts (e.g., 5 failed logins).
- Helps distinguish between routine activity and potential threats.

Temporal Constraints (Over What Time Window)

- Specify the time period within which events must occur (e.g., within 10 minutes).
- Enables detection of patterns spread over time, not single isolated events.



Data Quality and Onboarding Challenges

- **Incomplete Logs**
 - Missing critical fields or partial event records reduce detection capability.
 - Some sources may not provide required security relevant data.
- **Parsing Errors**
 - Incorrect or failed log parsing leads to data misinterpretation or loss.
 - Variations in log formats across devices complicate normalization.
- **Time Synchronization Issues**
 - Unsynchronized timestamps across systems hinder accurate event correlation.
 - Time zone differences and clock drift cause alert delays or false sequences.
- **Inconsistent Fields and Standards**
 - Different devices represent similar events using diverse field names and values.
 - Makes writing universal detection rules complex and error-prone.
- **Junior Engineers and Data Onboarding**
 - Data onboarding is crucial but repetitive, involving mapping, normalization, and troubleshooting.
 - Junior engineers often perform onboarding to build foundational knowledge and learn infrastructure details.



Onboarding experience is essential for understanding data flows and improving detection coverage.

Recap

- **Infrastructure Monitoring & Log Aggregation:** IT infrastructure spans servers, endpoints, networks, cloud, and identities. SIEM centralizes logs from all these sources, normalizing diverse data formats into unified security intelligence for detection and response.
- **SOC Organization & Incident Workflow:** SOC's operate in tiers (Tier 1 triage, Tier 2 investigation, Tier 3 hunting) and follow standardized workflows: intake → triage → escalation → containment → eradication → recovery → lessons learned, supported by integrated tools (SIEM, EDR, SOAR, ticketing).
- **Detection Rules & Correlation:** Detection rules translate business security use cases into technical logic by defining conditions (what to detect), thresholds (how many events), and temporal windows (within what timeframe). SIEM correlates events across systems to surface meaningful alerts while balancing detection coverage against alert fatigue.
- **SIEM's Central Role:** SIEM is the nervous system of security operations—it aggregates, normalizes, correlates, and alerts on security data but does not prevent threats alone. It works alongside EDR (endpoints), NDR/IDS (networks), and SOAR (automation) to provide comprehensive visibility and enable rapid response.
- **Operational Reality:** SOC success depends on data quality (complete, consistent logs), human factors (managing cognitive load, shift work, clear playbooks), and continuous improvement. Junior analysts are critical to data onboarding and alert triage—the foundation for mature threat detection.

Is SIEM Enough?



- SIEM Excels at log correlation but lacks automated response capabilities.
- Detection ≠ Response: SIEM identifies threats but doesn't stop attackers mid-attack.
- Manual repetition across tools wastes 60-70% of analyst time.

Enter **SOAR**: Automation & Orchestration

- SOAR builds on SIEM data to automate repetitive tasks and orchestrate multi-tool responses
- The Complete Pipeline: SIEM + SOAR
 - Together: End-to-end security operations at enterprise scale.



Thank you – Questions*

Andreas L. Symeonidis

Giorgos Siachamis

Dimosthenis Natsos

ISSEL – AUTH / Cyclopt

{symeonid, gsiacha, dcnatsos}@ece.auth.gr



*The presentation is based on online sources (referenced) and prototype ISSEL and Cyclopt research